

Production Cutover Checklist

The **go / no-go** for the first real production-config boot — the last hard blocker from the readiness audit (P0-5). Work top to bottom; do not open to customers until every GO condition is green. Grounded in the code (`security-flags.ts`, `/api/health`, `cutover-smoke.mjs`).

- Go / No-Go
- Grounded in code
- Blocker P0-5

01 The gate

The app **fails closed at boot** (`instrumentation.ts` → `assertBootHardening`) when production hardening is wrong — a misconfigured deploy won't start, or `/api/health` returns **503 hardening: fail**. This checklist confirms it booted *correctly*, not just that it booted.

02 Environment — must SET

Core mode switches

- ☐ MIAI_AUTH_MODE=oidc
- ☐ MIAI_WALLET_MODE=http
- ☐ MIAI_MODEL_MODE=azure (or gateway)
- ☐ NODE_ENV=production
- ☐ APP_BASE_URL / NEXT_PUBLIC_APP_URL = real public origin

Data

- ☐ DATABASE_URL = Azure Postgres
- ☐ PG_SSL_REJECT_UNAUTHORIZED=true (or unset — defaults to verify-TLS)
- ☐ UPSTASH_REDIS_REST_URL + _TOKEN — required before > 1 replica

Identity (OIDC)

- ☐ MIAI_OIDC_ISSUER · CLIENT_ID · CLIENT_SECRET
- ☐ MIAI_OIDC_AUDIENCE · JWKS_URL

Model — Azure OpenAI

- ☐ AZURE_OPENAI_ENDPOINT · API_KEY · API_VERSION
- ☐ AZURE_OPENAI_DEPLOYMENT + _DEPLOYMENT_LARGE
- ☐ gateway path: MIAI_MODEL_GATEWAY_URL · KEY

Wallet — MyInstantAI gateway (the P0-4 decision)

- ☐ MIAI_WALLET_API_URL · API_KEY
- ☐ ⚠️ Confirm the gateway is **live, durable & idempotent** — the outstanding MyInstantAI-side dependency

Secrets — strong (≥16, not a default), from Key Vault

- ☐ OAUTH_TOKEN_SECRET · OAUTH_STATE_SECRET · EMBED_KEY_SECRET
- ☐ MIAI_SESSION_SECRET · WEBHOOK_SINK_SECRET · CRON_SECRET (set-but-weak now fails boot)

Telemetry

- ☐ APPLICATIONINSIGHTS_CONNECTION_STRING

03 Environment — must UNSET (these silently weaken prod)

- ☐ SANDBOX_MODE — **unset**. If set alongside real rails, boot now **refuses** (PR #97). The #1 thing to verify.
- ☐ ALLOW MOCK_RAILS / I_UNDERSTAND MOCK_RAILS_IN_PROD — **unset** (they force mock auth/wallet)
- ☐ ALLOW_SANDBOX_IN_PROD / I_UNDERSTAND_SANDBOX_IN_PROD — **unset**
- ☐ ALLOW_EMBED_ORIGIN_STAR / I_UNDERSTAND_EMBED_ORIGIN_STAR — **unset**
- ☐ ALLOW_FILE_FALLBACK_IN_PROD / I_UNDERSTAND_FILE_FALLBACK_IN_PROD — **unset**
- ☐ PG_SSL_REJECT_UNAUTHORIZED **not 0**

04 GET /api/health — the go / no-go table

`curl -s https://<fqdn>/api/health | jq` — GO requires HTTP 200 and `status:"ok"`.

FIELD	REQUIRED PROD VALUE	WHY IT MATTERS
status	ok (200)	degraded = incomplete config / Redis down; failing (503) = hardening failed
hardening	ok	fail ⇒ 503; the boot gate rejected the config
mockRailsAllowed	false	NO-GO if true — mock auth/wallet or a leaked SANDBOX flag
sandboxMode	false	NO-GO if true — SANDBOX_MODE=1 on prod (surfaced by #97)
nodeEnv	production	NO-GO otherwise — anything else disables hardening
authMode	oidc	real per-user identity
walletMode	http	real billing gateway
modelMode	azure / gateway	real model
database	configured	Postgres wired, not the file fallback
storeBackend	postgres	the store is actually Postgres
storePing / store	ok / hydrated	DB reachable + migrations applied
oidcIssuer / walletUrl / modelUrl	set	⚠ presence only, not reachability — \$06 proves reachability
redisConfigured / redisPing	true / ok	required before > 1 replica
config	absent	incomplete ⇒ a required partner URL is missing

05 Cutover smoke — `pnpm smoke:cutover`

Anonymous pass (health + catalog + embed-401)

```
BASE=https://<fqdn> pnpm smoke:cutover
```

- ☐ All checks ✓; the logged line reads `auth=oidc wallet=http model=azure store=postgres/ok`

Authenticated pass — after a real OIDC login, with the Bearer token

```
BASE=https://<fqdn> TOKEN=<real-oidc-jwt> pnpm smoke:cutover
```

- ☐ `wallet, rent <agent>, agent <id>` all ✓ — the OIDC → wallet → rent → agent path end-to-end

06 Live end-to-end proof (what `/api/health` can't confirm)

- ☐ **Real OIDC login** in a browser → authenticated (not the mock/demo identity)
- ☐ **One real chat turn** returns a genuine model answer, **not** a deterministic mock line. Guards the known gap: the rails check verifies `MIAI_MODEL_MODE≠mock` but not that the key is present — a missing/rotated key silently falls back to mock
- ☐ **One live connector action** (real Slack post / calendar booking on a *connected* connector) succeeds — and an *unconnected* one returns the honest "couldn't complete" (PR #99), never a fake confirmation
- ☐ **One real wallet debit** reflected in the MyInstantAI gateway ledger (billing is durable, not the mock wallet)

Optional — costs model tokens

```
BASE=https://<fqdn> pnpm smoke:live-llm      # single live-LLM smoke  
BASE=https://<fqdn> pnpm smoke:live-llm:matrix # broader matrix
```

- ☐ Live-LLM smoke passes — also the start of closing the still-open live-model eval gap

07 Known gaps to handle during cutover

- ☐ **Migrations run on first request, not at boot** (`ensureMigrations` fires on first Postgres access; the first `/api/health` triggers it). A failure shows as degraded health / 500, not a failed deploy — hit `/api/health` and confirm `store:hydrated` before traffic. See [MIGRATION_RUNBOOK.md](#).
- ☐ **Bicep hard-wires `MIAI_MODEL_MODE=gateway`** — for the azure model path, edit `infra/azure/main.bicep` to add the `AZURE_OPENAI_*` env + toggle first.
- ☐ **No gated/audited prod release yet** — put the `az deployment` behind a reviewer-gated GitHub Environment on a pinned image SHA, and **verify a rollback** (redeploy the previous GHCR tag) before real traffic.
- ☐ **Redis before scale** — the Bicep caps `maxReplicas` at 1; provision Upstash/Azure Cache + set `UPSTASH_*` before raising it, or rate limits/sessions aren't shared.

08 Go / No-Go summary

GO — ONLY WHEN

\$02 set · \$03 unset · \$04 every row green
(`mockRailsAllowed:false`, `sandboxMode:false`,
`hardening:ok`, `storeBackend:postgres`) · \$05 both smoke
passes · \$06 real login + real chat + live connector + real debit all
proven.

IMMEDIATE NO-GO

- ☐ `mockRailsAllowed:true`
- ☐ `sandboxMode:true`
- ☐ `nodeEnv≠production` · `hardening:fail`
- ☐ a chat turn that returns a canned/mock answer
- ☐ the MyInstantAI wallet gateway not yet durable

Companion docs: [AZURE_DEPLOYMENT.md](#) · [MIGRATION_RUNBOOK.md](#) · [RAILWAY_DEPLOY.md](#)